

Déclaration du Périmètre SMSI — TechShop SAS

Version : 1.0
Date : Juin 2026
Auteur : Dorian Poncelet (Consultant GRC)
Approuvée par : Marie Laurent, Directrice Générale
Statut : Validé
Référence : ISO 27001:2022 — Clause 4.3

1. Objet

Ce document définit le périmètre du Système de Management de la Sécurité de l'Information (SMSI) de TechShop SAS, conformément à la clause 4.3 d'ISO 27001:2022.

La définition du périmètre est un acte fondateur du SMSI : ce qui est **dans** le périmètre est soumis à toutes les exigences de la norme. Ce qui est **hors** périmètre doit être justifié explicitement — toute exclusion non justifiée est une non-conformité en audit.

2. Déclaration du périmètre

Le SMSI de TechShop SAS couvre l'ensemble des activités liées à la gestion de la boutique en ligne, de l'ERP, et des données associées (clients, commandes, ressources humaines), hébergées sur l'infrastructure OVH et les services cloud utilisés pour soutenir l'activité e-commerce depuis le siège de Toulouse.

3. Périmètre inclus

3.1 Sites physiques

Site	Adresse	Activités couvertes
Siège social	Toulouse (31)	Direction, administration, SI, RH, marketing

Site	Adresse	Activités couvertes
Entrepôt logistique	Labège (31)	Préparation commandes, stocks, expéditions

3.2 Systèmes d'information et applications

Système	Rôle	Hébergement	Inclus
Site e-commerce WooCommerce	Vente en ligne B2C et B2B	VPS OVH (2 serveurs)	[OK]
ERP Odoo 17 Community	Gestion opérationnelle (stocks, commandes, RH, comptabilité)	Cloud OVH	[OK]
Google Workspace (email, Drive, Docs)	Communication et collaboration interne	Google Cloud (UE)	[OK]
Grafana + Prometheus	Supervision et monitoring infrastructure	VPS OVH	[OK]
VPN WireGuard	Accès sécurisé à l'administration des systèmes	VPS OVH	[OK]
AWS S3 (eu-west-3)	Sauvegardes des données critiques	AWS Paris	[OK]
Cloudflare (CDN + WAF)	Protection et performance du site web	SaaS mondial	[OK]

3.3 Données couvertes

Catégorie	Volume	Classification	Inclus
Données clients (nom, email, adresse, commandes)	~15 000 personnes	Secret	[OK]
Données RH (contrats, paie, évaluations)	47 salariés	Secret	[OK]
Données financières internes (CA, marges, fournisseurs)	—	Confidentiel	[OK]
Données de catalogue (produits, tarifs)	~5 000 références	Interne	[OK]
Logs et journaux d'accès	—	Confidentiel	[OK]
Sauvegardes complètes	—	Secret	[OK]

3.4 Processus métier couverts

- Gestion des commandes clients (de la prise de commande à la livraison)
- Gestion des retours et du service après-vente
- Gestion des stocks et relations fournisseurs
- Gestion administrative des ressources humaines
- Supervision de l'infrastructure technique

- Gestion de la sécurité de l'information (le SMSI lui-même)

3.5 Personnes couvertes

- Les 47 salariés de TechShop SAS
- Les prestataires IT ayant accès aux systèmes (accès VPN ou direct)
- Les sous-traitants traitant des données TechShop (OVH, AWS, Google, Stripe...)

4. Périmètre exclu

4.1 Exclusions avec justification

Élément exclu	Justification	Interface avec le périmètre
Traitement des paiements Stripe	Stripe est un sous-traitant PCI-DSS certifié SAQ A. TechShop ne stocke aucune donnée de carte bancaire. La sécurité du traitement des paiements est entièrement déléguée à Stripe par contrat.	Flux entrant : tokens de paiement uniquement. Sortant : confirmation de paiement.
Traitement des paiements PayPal	Idem Stripe — PayPal est certifié PCI-DSS. Les données bancaires ne transitent pas par les systèmes TechShop.	Idem Stripe
Infrastructure des transporteurs (Colissimo, DPD)	Systèmes appartenant aux transporteurs. TechShop transfère uniquement les données de livraison nécessaires (nom, adresse) via API.	Flux sortant : données de livraison (nom, adresse) uniquement.
AWS S3 us-east-1	Ce bucket est en cours de suppression (non-conformité RGPD NC-01 — Mesure M02 du PTR). Exclu du périmètre SMSI car transfert hors UE non conforme, à éliminer avant fin juillet 2026.	Aucune interface active après migration
HubSpot Free (CRM marketing)	En cours de remplacement ou mise à niveau (non-conformité NC-02). Exclu temporairement car absence de DPA conforme RGPD.	Flux sortant : emails prospects uniquement
Postes personnels des employés en télétravail	Les équipements personnels ne sont pas gérés par TechShop. Seul le VPN WireGuard (inclus dans le périmètre) contrôle l'accès depuis ces postes.	VPN obligatoire pour tout accès aux systèmes depuis un poste personnel

4.2 Justification globale des exclusions

Les exclusions du périmètre SMSI de TechShop SAS obéissent à deux logiques :

Délégation contractuelle maîtrisée : Stripe et PayPal traitent les données de paiement sous leur propre certification PCI-DSS. TechShop conserve la responsabilité de la relation

contractuelle (DPA, SLA) mais ne peut pas auditer directement leurs systèmes. L'exclusion est compensée par les contrôles A.5.19 à A.5.22 (gestion des fournisseurs).

Non-conformités en cours de correction : AWS us-east-1 et HubSpot Free sont exclus temporairement car leur inclusion créerait une non-conformité structurelle au SMSI. Leur réintégration (sous forme conforme) est planifiée avant septembre 2026.

5. Interfaces avec l'extérieur

Les interfaces entre le périmètre SMSI et l'extérieur constituent des points de risque qui font l'objet de contrôles spécifiques :

Interface	Direction	Données échangées	Contrôle en place
Clients -> WooCommerce	Entrante	Données de commande, identifiants	TLS 1.3 + Cloudflare WAF
WooCommerce -> Stripe	Sortante	Token de paiement (pas de numéro de carte)	HTTPS + API Stripe PCI-DSS
WooCommerce -> Transporteurs	Sortante	Nom, adresse de livraison	API HTTPS
OVH -> AWS S3 eu-west-3	Sortante	Sauvegardes chiffrées	Chiffrement S3 + IAM restrictif
Employés -> Systèmes (remote)	Entrante	Tous les accès distants	VPN WireGuard + MFA
Google Analytics -> Site	Entrante/Sortante	Comportement visiteurs (anonymisé)	IP anonymisation + consentement

6. Représentation schématique du périmètre



?

??

?

?

?

?

??

?

CLIENTS ? ? STRIPE ? ? TRANSPORTEURS ?

?(Internet) ? ? (EXCLU PCI) ? ? (EXCLU API) ?

??

Hors p?rim?tre ? interfaces contr?l?es

7. Révision du périmètre

Le périmètre SMSI est révisé dans les cas suivants :

- Annuellement, lors de la revue de direction (Clause 9.3)
- En cas d'ajout ou de suppression d'un système d'information critique
- En cas de changement de prestataire cloud
- En cas d'ouverture d'un nouveau site physique
- Suite à une acquisition ou une fusion

Prochaine révision planifiée : Juin 2027

Révision anticipée probable : Après migration HubSpot (septembre 2026) — réintégration dans le périmètre SMSI sous forme conforme.

Document classifié : INTERNE

Archivage : Google Drive / SMSI / 02-Périmètre

Prochaine révision : Juin 2027